

EZarcade_hall题解

本身其实就是一个偏向于常规的板子题，想要完成后续利用，首先要先卡bug把游戏币卡到足够用，这里看程序逻辑其实可以看到，存在一个溢出行为，如果你买超过一定数量的游戏币，结算系统会出现无符号的溢出，从而只收取了很低的金币。

漏洞利用

在游戏运行函数里会置位对应的一个标志位，但是在弹出的时候，却只做了部分清除，导致了部分标志位的保留。而view函数只检查了这个保留的标志位，这就导致当游戏弹出后我们运行该函数会读取到隐藏内容，从而拿到泄露的地址。并且解锁管理员维护模式，维护模式里能够泄露同一栈帧里的局部指针，通过计算就可以拿到栈基址，该题开启了沙箱，杀掉了一些系统调用，因此默认的buf_size无法完成后续利用，所以需要采取栈迁移来获得更大的空间完成利用，通过覆盖低字节的rbp，以及配合leave; ret，能够实现该过程。迁移后正常orw即可拿到flag。